# IKP: Privacy Enhanced Authentication, ZKP and Proof of Personhood

BGIN Block 15 · Georgetown University Capitol Campus, 111 Massachusetts Avenue NW, Washington, D.C.

| | |
|---|---|
| **Date** | 16 October 2026 |
| **Room** | Room B (2416) |
| **Published time** | 11:30–13:00 |
| **Workstream** | privacy-enhanced-auth |
| **Status** | Draft for working-group review. Source: closed captions. |
| **Rule** | Chatham House Rule. Information may be used without revealing the identity or affiliation of speakers or other participants, directly or indirectly. |

This is a session record, not a transcript. Substantive discussion is retained with uncertainty and disagreement made explicit. Reported claims are not verified findings. Candidate agreements require working-group confirmation before use as decisions. Actions omit personal owners and identifying roles.

## Agreements

The following sentences stand on their own. These are candidate agreements and reported points of convergence for working-group review. Inclusion does not establish consensus, verify a technical claim, or record formal adoption. The working group must confirm each decision before it is cited as such. Claims that were only discussed, including figures and alternatives that were not adopted, remain in full under Discussion.

The session's object is a shared language for human assurance, not a single biometric product. Outcome, evidence, and governance are the three layers. Categories are not a score.

A valid proof can support the wrong conclusion. Key control is not identity. An agent bound to a person can still act outside that person's authority.

Linkability is sometimes required, including for credit and for risk assessment, and disclosure beyond the claim is a separate harm. The driver's-license example was uncontroversial.

A zero-knowledge credential does not, by itself, satisfy KYC or sanctions screening. The taxonomy's question list is a way to say which slice of an onboarding process a proof actually covers.

Where biometric and identity standards already define a term, the taxonomy should reuse them. ISO/IEC 30107, ISO/IEC 27551, and ISO/IEC 24745 were the concrete references.

A zero-knowledge proof over a template does not prove that a live person faced a real sensor. Capture is a missing dimension in the questions BGIN has been asking.

Liveness is a property of capture, not a peer method next to face recognition. Injection is a device-integrity problem and should be named separately from presentation attacks.

The aperture is a useful addition: uniqueness is always against some set, and the size of that set is a choice. The room singled this out as the contribution that most extends prior BGIN work. Freshness was accepted as related.

Dedicated hardware and ordinary cameras close different gaps. A taxonomy has to describe both, including systems that use both.

General-purpose device integrity is not something to assume. It can be measured separately and composed with a biometric. Different devices can carry different risk scores without becoming different uniqueness communities.

Agents get a human check at a different moment than enrollment. A verifiable trust community was accepted in the discussion as an aperture: unique inside, unlinkable across.

World ID, as described, proves humanity and uniqueness and does not, in online use, disclose the iris code. Reset rotates a key pair. A second enrollment does not create a second identity. Those were accepted as the design under discussion, not as an audit.

My Terms already has a narrow first agreement in its own standards process: no third-party cookies, first-party cookies only, when both sides carry the term. That was reported, not newly voted here.

The three contributions were worth continuing over lunch, and the taxonomy should be revised with the capture, aperture, and freshness comments. Documents were to be shared.

## Documents considered

The session referred to the following documents, repositories, and standards. Bibliographic identifications and factual checks added during review are marked as editorial clarifications; they do not imply that the links were spoken or that the meeting adopted the findings. Names of the people who introduced the material are omitted.

Working taxonomy of human-assurance outcomes, evidence, and governance, including the ten categories and the disclosure and linkability dimensions. No document title was spoken.

ProveKit, `https://provekit.org/` using Noir circuits. The website and language spelling were checked against the project site.

The ISO/IEC 30107 series on biometric presentation attack detection, cited in the discussion of liveness; the specific part was not established.

ISO/IEC 27551, Requirements for attribute-based unlinkable entity authentication. The standard and title were supplied in the chat; its review status was reported in the session.

ISO/IEC 24745, biometric information protection, cited for renewability. The lifecycle question was whether a zero-knowledge construction keeps that property.

Block 13 and Block 14 records: liveness listed as a method, rotation of unchangeable identifiers, an anonymity set of at least a million, agents receive tokens and not keys.

A July research-pathway note on BGIN privacy questions. No title or URL spoken.

Trust over IP ZKP task force; a W3C confidence-method task force for privacy-preserving confidence

methods, including age assurance.

W3C verifiable-credential data model and DID documents; the Trust over IP trust triangle.

IEEE white paper, from 2021 principles, on IEEE Xplore: human centricity, decentralized identity, distributed processing, heterogeneous control, self-healing.

TRACER transparency-and-risk question list, IEEE Xplore. Acronym spelling [unverified].

IEEE 7012-2025, My Terms. SD-BASE is the documented services-only agreement; the particular cookie example needs its contribution source.

A Google zero-knowledge protocol, unnamed, under comparison [unverified].

Internet Identity Workshop, April, cited for three agent-custody failure modes. No paper title.

## Discussion

The following is the substance of the session. It preserves claims, figures, alternatives, and objections. Discussion does not establish a decision. Any candidate agreement requires explicit working-group confirmation.

Privacy-enhanced authentication and zero-knowledge proofs. The subject has been in BGIN workshops for at least six blocks, and the archive was described as something later agent tooling can survey. The agenda was changed for people online: three pre-submitted contributions, then lunch discussion. The discussion considered a proof-of-personhood taxonomy and World ID as an example. One was a trust-fabric view centered on social proofs and verifiable credentials rather than biometrics. One addressed passive face verification on ordinary cameras. Lunch was to continue the discussion; the room did not try to close the taxonomy in the session.

**Why a biometric plus trusted hardware, rather than a web of trust or a government credential.** The proof-of-human project was described as started in 2019. More than 20 million people were said to have been verified. The design question stated was narrow: how to ensure that somebody is a unique human once AI can forge the signals people use to prove attributes about themselves, including vouching.

A web of trust was ruled out. Connections on social platforms do not survive fake profiles that vouch for each other, or real profiles co-opted to vouch for an agent. A government credential such as a passport was treated as evidence that a trusted government believes the holder is a unique human, and rejected for two reasons. Not everyone has a credential that is globally recognized. And the issuer remains a trusted third party that can, on a given day, decide whether someone counts as unique. That was called a fault line for one-human-one-vote and for any setting where proof of human is meant to secure agency. The design choice was to make trusted hardware the issuer, at a protocol level, so attestation is not an authority's daily decision.

Irises were justified as entropy, not as a preference for biometrics in general. Face unlock was described as one-to-one: a false match on the order of 1 in 30 million is tolerable on a phone because the lookalike still has to have that phone. A network that must distinguish one person from everyone else needs a one-to-N comparison. A figure of about 1 in 30 trillion was cited in support of iris-based uniqueness.

The draft had labeled it a false non-match rate, but the intended error metric is unverified; it should not be used as a measured rate without checking the underlying material. DNA sampling was rejected as too much entropy and too invasive. Fingerprints were rejected as less durable, easier to smudge or scar, easier to lift, and slow to image. The room noted in passing that "proof of personhood" and "proof of human" are not the same label and that the taxonomy has to keep them apart.

**What is stored, and what a later proof discloses.** An orb visit was described as about a minute of on-device computation. The device derives a long hash of an iris code. That hash is split into pieces and routed to nodes of an anonymized multi-party computation (AMPC) network. The hash exists so the same person cannot enroll twice: the same code is regenerated, checked against the shares, and a "witnessed before" result blocks a new World ID. After enrollment, online use was said not to disclose the iris code. A zero-knowledge proof attests that a public key was inserted into a Merkle tree on Ethereum at signup. The holder self-custodies the private key used to sign later attestations. An OPRF construction was cited so that the proof does not reveal which human is behind the attestation and so that uses cannot be linked across platforms. The orb was also said to capture a face image, held in a self-custodied package signed by the device, analogous to a passport signed by an issuing authority.

**Taxonomy: outcome, evidence, governance.** The taxonomy starts from a language problem. Systems answer different questions and then talk as if they were the same question: is there a human behind the account, is the right human behind a credential, is the right human behind an agent's action. A valid proof can support an invalid conclusion. Control of a key is not the right human behind that key. An agent bound to a human principal can act outside the authority that principal gave.

The split is three layers. Outcome: what the relying party may conclude. Evidence: what supports the proof (credentials, biometrics, zero-knowledge proofs, and who made the underlying determination). Governance: why the proof is warranted, and what confidence is justified.

Ten human-assurance categories were grouped into four clusters, offered as high-level and not as a score. They are not meant to be compared on one horizontal scale. The clusters cover legal or civil identity (is this person who they say they are), humanity (is this a human), uniqueness (is this person unique), and then credential control, presence, attributes, roles, and actions. Agent authority was called out as needing its own deep dive.

The captured list contains five assurance dimensions and two additional privacy dimensions; the stated count of six assurance dimensions could not be reconciled:

Category: what was established.

Strength: how much confidence is warranted, and against which threats.

Evidence: what supports the claim, and who determined it.

Scope: which relying party, for what purpose, in what domain.

Validity: how long the assurance lasts, and whether it can be revoked.

Disclosure: what the relying party learns.

Linkability: who can correlate which events, across what context, for how long.

Applied to products in that same effort: World ID was offered as proof of humanity and uniqueness; Selfie Check as proof of presence; proof of attributes, such as a passport used to show age or nationality, as a separate conclusion. Other products were mentioned and not walked through.

**Linkability as a metric, not a goal.** A comment from the room: in zero-knowledge work, unlinkability is the property you try to achieve, so the taxonomy might be clearer if unlinkability is the outcome and linkability is the test. If linkability is a sliding scale whose zero is unlinkability, the dimension becomes a risk assessment.

The reply was that "privacy-preserving" had been considered as a goal and then split, because some user–relying-party pairs want linkability or do not care about it. The dimension was left as a metric of how much linkability exists, not as a requirement that it be zero. The wording change was left open.

The discussion considered the slides useful for technology-neutral regulatory assessment. The useful object is a chain of questions: what is established, at what confidence, for what purpose. That chain is how one would test the claim that a zero-knowledge credential "solves KYC." A certificate that an identifier is not on a sanctions list does not discharge sanctions compliance, and it does not discharge KYC. The same chain asks which slice of onboarding is actually met: name, nationality, attributes that speak to risk, or a credit determination. The collateral-disclosure example was the usual one: a driver's license shown to prove age over 21 reveals far more than age. Linkability was accepted as necessary for some of those larger risk assessments even where non-linkability is the privacy goal.

**Use cases said to be in adoption.** Some are built by others on the primitives; some are with design partners.

A Zoom integration. The self-custodied World ID, a liveness selfie, and the face image in the device-signed package are checked against the image the Zoom camera sees. A three-way match produces a badge that the participant is a unique human and not a deepfake.

The lending product Credit was discussed. On-chain credit risk was described as mostly missing information, including fake scores and easy default. The credit account is anchored to a World ID with a zero-knowledge proof, so the account is not revealed as belonging to a named person. A new account presents the same nullifier and is refused. The lender does not gain recourse to seize funds. The sanction is exclusion from future credit. The product was described as starting at a $5 loan and stepping the amount up as loans are repaid, so a native repayment history can be shown to another protocol as a trust score bound to the same World ID. Default stops the next loan. This was the example where linkability inside one service is the point.

Agent delegation. A holder can bind agents to one World ID and rate-limit what they may do. The April demonstration was a limited merchandise drop: one hat per human. A thousand agents still share one proof. Once that proof is consumed, a second agent cannot buy. The same pattern was offered for concert tickets, website access, and other rate limits.

**Map the words onto existing standards.** A standards comment: the taxonomy has to be checked against agreed biometric standards and identity standards. Liveness, presence, and linkability are not understood the same way from every background. Where a concept is already defined, reuse it. From

the ISO/IEC JTC 1/SC 27 identity-management work, unlinkable authentication already discusses granularity: unlinkability inside a fixed context, versus unlinkability across domains. A link was to be put in the chat. Later in the same session that line of standards was named as ISO/IEC 27551, described as under review.

**Second enrollment, reset, and loss.** The iris code was described as deterministic: the same image detail yields the same code. Scanning again does not produce a second World ID, including the suggestion of one identifier per eye. A reset mode is different. The holder returns to an orb, the old public key is removed from the Merkle tree, a new key pair is inserted, and the holder self-custodies the new private key. The MPC check is what blocks a second identity: the code is split, each share is compared with what the nodes already hold, and a full match means "already verified." Reset is a different mode that deletes the previous public key and registers a new one. The comparison is on-device plus the MPC network, not a manual review. The orb was said to use an Nvidia Jetson-class chipset to turn iris texture into that code.

A lost private key can be exported and backed up. If it is gone, the holder re-verifies and receives a new public key. The iris code does not change.

**Why five nodes, and who operates them.** Five was described as the number of nodes signed up now, not as a protocol constant. The aim is as many independent operators as possible. Splitting the code is what makes collusion necessary: one party holding the whole code could try to re-derive a fuzzy image and then duplicate identities. Recombination was said to require all of the current share-holders. More nodes raise that bar and add redundancy so that not every node must be online. Operating a node was described as expensive in bandwidth, compute, and storage even though each share is "small," and reducing that cost was called active work. A node at the University of Tokyo was described as the newest addition. A second institutional contact around that node was discussed later and left unclear; no name is recorded here.

**Where orbs go, and what is not open source.** The orb hardware design was described as open source, with a vision that others manufacture devices and act as authenticators for canonical World IDs. Near-term distribution is aimed at places where the credential is immediately useful, not at blanket coverage in the hope that a use appears. A year earlier, "verify you are human" was said to be hard to explain; a token incentive existed partly for that reason. The claim now is that AI has made the need intuitive, so deployment follows demand: an orb in an office so staff can be onboarded to a World ID for the Zoom case, or bound to an internal credential that the person can carry to another employer. The same credential is then available for ticket bot-controls or for delegation through access and signature products. Devices are being made smaller and cheaper, with a screen that walks through enrollment, including placements already tried in malls and the idea of a coffee shop. The stated end state is tens or hundreds of thousands of devices, including ones people build themselves.

The supply-chain objection was accepted. The piece that is not open source is the security chip that shows the device has not been tampered with and that it may issue a World ID on the canonical network. Trusted execution environments were described as the route to let other hardware produce an authentic signature without that proprietary chip. A self-built device that does not pass the gate

could still create cryptographically similar identifiers. Those would not be canonical World IDs on this protocol. Five such devices would be five non-canonical identities. The reply was that relying parties will trust the canonical registry because of network effects, not because homemade hardware is incapable of computing a proof.

One device enrolls many people. A plugged-in unit can run continuously. Enrollment was said to take about one to two minutes depending on the network. The device was said not to have memory for more than one image at a time, so a second enrollment cannot run unless the previous image was deleted. That memory limit was offered as evidence of deletion, alongside a check that deletion occurred.

**A palm-based credential on the same network.** A grant was said to have seeded a separate, competing proof-of-human credential based on a palm scanner (captions render this as "base scanner," "OnBase scan," and "palmade scanner" [unverified]). Suggested uses were a fast payment point and an age check at a bar that does not show an identity document. The contrast drawn was scale: an orb will not sit at every checkout, and a palm scanner might. The claim was that the existing network lets that system run without rebuilding the uniqueness infrastructure.

LASIK was said not to change the iris, because it reshapes the cornea. Scarring or loss of an eye has no good re-enrollment answer. The fallback stated was that a smaller comparison set makes weaker biometrics viable; iris was chosen because the set is everyone.

**ProveKit.** Separate from the orb, a library for generating zero-knowledge proofs on ordinary hardware. The problem stated: proofs are expensive to compute and store; a passport proof that must leave the phone, be computed on a server, pass through a trusted setup, and land in a block is both a bad user experience and a weaker privacy claim. ProveKit is meant to let a circuit be written and proved locally, without that setup, quickly, and with a small proof. Passports were the understandable case. A diploma was the generalization: any credential with a trusted issuer and a machine-readable form can have a circuit. The library was described as what the World ID proofs were researched with, and as usable for other credentials.

A stated limit: comparing a live face image to an image on the device is still too heavy for a phone to do reliably and quickly. That comparison is the long-term target. The release was described as about a month before this meeting, after roughly two and a half years of work, with outside cryptographic contributors. One collaborator was named clearly enough as Nethermind. Another name rendered "Tasio" is [unverified]. Version 1 is out. Version 2 was hoped for within a year, possibly within three to six months, with the claim that AI tooling is shortening that cycle. The project website is `https://provekit.org/` the captioned domain has been corrected against the project site. It is open source. A room comment: previous attempts to run zero-knowledge circuits on a phone have failed thermally; local proving that does not do that is the interesting property. The circuit language is Noir, verified against the project website; the caption rendering was unclear. Contribution was invited.

**A zero-knowledge proof does not prove the capture.** The central argument about passive face matching on ordinary cameras was: a zero-knowledge proof over a biometric proves a statement about a template and proves nothing about how that template came to exist. The proof can carry a match, uniqueness, or an attribute such as age over 18. It assumes a live person stood in front of a real sensor.

Today that assumption is trust in hardware or trust in a vendor. The proof says what. It does not say how, against whom, or when.

The gap was tied to BGIN's own questions. Materials from earlier blocks, and a July research-pathway note, were described as starting once the biometric already exists as data. They do not ask how it got there. Block 14's answer was dedicated hardware that signs the capture. Most people will meet proof of personhood through a phone or laptop camera, where there is no signed sensor. That is the setting in which this contribution's capture failures were said to have been observed.

Four threads picked up from earlier blocks:

Block 13 listed liveness next to face recognition and social verification, as if it were a method. The argument here: liveness is a property of a capture that every biometric method depends on.

Block 13 asked for rotation even of unchangeable identifiers. A face cannot be rotated. The model version, the key the template is bound to, and the community the template is valid in can be rotated.

Block 14 recorded an anonymity set of at least a million. That number was called a scope choice, not a law. Uniqueness should be proved inside the community that matters — a platform, an ecosystem, a maintainer group — rather than against one global set. That dial was named the aperture.

Block 14 settled that agents receive tokens, never keys, and left open what proves a human was present when the token was issued.

Three capture failures that a proof will still accept:

Presentation attacks: a photo, a screen, a mask. This is what liveness models are for. ISO/IEC 30107 was cited as the test method.

Injection: the feed is replaced behind the camera, so the model sees a perfect face. On general-purpose hardware this is mostly device integrity. The taxonomy should say so, rather than letting the word "liveness" cover it.

Enrollment substitution: a real, live, wrong person enrolls. A biometric has no source of truth for who was supposed to appear. That is a process and an evidence chain.

Three dimensions proposed as additions:

Capture assurance: which of those failures are in scope, how each is mitigated, and whether the mitigation sits inside or outside the proof's trust boundary.

Uniqueness aperture: global, as in the World ID design, or sized to one community. A smaller community links less across communities and leaks less widely, and it is a smaller crowd to hide in. Global uniqueness and unlinkability pull against each other. ISO/IEC 27551's unlinkable-authentication requirements were cited again. The claim was that the aperture is how a uniqueness system meets that standard: unique inside one community, unlinkable across communities.

Freshness: enrollment proves that a unique human enrolled. It does not prove who holds the credential now. A device-bound presentation proves control of the device, not presence of a person. The question is how recent the last verification was, and whether it must be repeated.

Dedicated hardware and ordinary cameras were compared as postures, not as a ranking. The same proof-of-human deployment was said to span both: the orb, and the selfie presence check described earlier. The taxonomy has to describe both. Dedicated hardware was said to win on capture provenance. General-purpose hardware was said to win on reach, with deployments from client-side, edge, on-premises, or cloud. Empty cells on the dedicated-hardware side of the comparison were described as the taxonomy doing its job: nothing has been written down there yet.

An explicit status check: this face-verification line has no zero-knowledge proof in production. The work is in the Trust over IP task force, and in a W3C confidence-method task force that might inherit it for privacy-preserving confidence methods, including age assurance.

**Revocation without rotating a face.** Returning to the Block 13 question: a face cannot be rotated, and everything around it can. A template from model version N was said not to match version N+1, so a new model re-enrolls everyone without changing the face. A new credential handles one person. A new aperture removes someone from one community and leaves other communities alone. ISO/IEC 24745 already names renewability. The open question put to the group: does a zero-knowledge construction preserve renewability, or does it freeze the template into a long-lived commitment? The discussion reinforced the point without adopting a design decision: a property that holds at one step of a lifecycle is not automatically preserved through the rest of the workflow. Freshness of disclosure, including some quantitative work on how private information decays, was offered from the room as related and to be shared back.

**Agents: three moments.** A personhood credential says a human existed at issuance. It does not say a human authorized this action. Three moments were distinguished, with different privacy costs and different capture needs: enrollment, delegation, and key actions. The proof-of-presence product described earlier was classed as a check at the third moment, a human at the action. The approach being built is a biometric anchor at delegation, then a step-up recheck when something changes.

From the Internet Identity Workshop in April, three conditions were cited where people working on agentic custody do not know what should happen: intent drift, where the agent is cryptographically correct and semantically wrong; the agent seeking a permission outside the original scope; the agent appearing in a new environment and asking to be trusted on the sender's name. A verifiable trust community was defined as an aperture: uniqueness inside it, unlinkability across communities. The personhood credential makes the human a node. A fresh human check at delegation is what keeps a person attached to the agent acting from that node.

The room's reaction: the aperture — which template, which set, against whom — is the piece that most adds to BGIN's existing work. Further development of the taxonomy and follow-up collaboration were proposed. Contributions were to be made available.

**Device integrity is not assumed.** A question on the injection row: does "device integrity" mean the device is assumed to have stayed intact, or that integrity is enforced in the device? Those are different restrictions on which devices the check can run on. The questioner is working on injection-attack standards.

The answer had three parts. Integrity of a general-purpose device would not be assumed. This work does not itself measure device integrity; the focus is the biometric. Device-integrity measurement was described as a separate product that can be composed in: an SDK inside a mobile application that reports whether the operating system is broken, whether the camera is real, and whether injection is happening. The picture offered was a set of composable checks, biometric from one provider and integrity from another. An Android presentation at the Geneva GDC meeting was cited in support: identity-wallet work aimed at making the capture chain trustworthy when a wallet is opened with face verification, in the orbit of GlobalPlatform certification discussions. Context and which extra SDKs are present decide the restriction, not a single device class.

A follow-up: if the same face proof can be sent from two phones, should a higher-integrity device attach a signal that its proof is worth more? The reply mapped that onto a risk score at a moment. Scores would not be equal across devices and could be weighted. It was not mapped onto a different uniqueness set. The mental model offered was an adversarial pipeline in front of the biometric check — liveness, device integrity, and other signals — scaled up or down, while the community, the collection, and the embeddings stay the same.

**Trust at the edge, without a biometric.** The third contribution moved off biometrics. The proposed objective is safe, fair, and trusted interactions. A program on foundations of trust in communication, interaction, and transactions between any two entities was described as already kicked off, including the question of trust in the device being used.

The term introduced was "my intelligence": intelligence of an entity at the edge, deliberately not called artificial intelligence. Data, inference, and interaction are meant to sit at the edge rather than in a central store.

The slide narrative was an ordinary person whose information sits in a hundred or more places, which was offered as a statistical claim. Each place profiles them. The benign outcome is a discount. The harmful outcome is a scam by someone who knows more than the person does, and whom the person cannot identify. The person does not know whether data were sold or shared through a partnership, and does not know who or what they are interacting with. Recent agent-security incidents at well-known AI companies, and public talk of human centricity, were noted. Five architecture principles were said to have been written in 2021 and later published as an IEEE white paper on IEEE Xplore.

From the bottom of that stack:

Human centricity: the person controls assets, and data is the asset.

Identity decentralization: identity and the means to prove it in a tamper-evident way sit at the edge. This is the self-sovereign identity and verifiable-credential layer.

Distribution of processing: holdings are not in one place that can be taken whole. A blockchain was cited as one way to get that distribution, not as the only way.

Heterogeneity of control: in a typical web service the same company builds the system and supplies the security controls, so one failure fails the system. Controls, credentials, or proofs should come from different places. The human analogy was a birth record from a local authority, a driver's license from a

motor-vehicle agency, a passport from a state, a visa from another state. One company issuing "the identity" was called a concentration risk, both as security and as power over the person.

Self-healing: once verification happens at the edge, different networks and groupings can form under the person's control. That was described as an intelligent system that stays secure because checks run along the chain.

The identity contrast was the familiar one. A centralized or federated model has an issuer, a verifier, and a database that holds the identity and is used both to issue and to check. A decentralized model issues the credential to a wallet at the edge. A verifiable data registry holds the issuer's public key. The registry can be a blockchain because of integrity; it need not be. The credential is signed with the issuer's private key and a DID and held by the holder. The verifier checks a proof by reading the issuer's public key from the registry. The issuer is identified through the DID document. This was identified as the trust triangle published through Trust over IP, with the W3C verifiable-credential data model beside it.

Four controls on a data exchange, whether verifier–holder or some other pair:

Assessment: the person can see what they are about to interact with. A paper called TRACER was described as a first question list for that, from a privacy-focused team inside the same program, recently on IEEE Xplore. The acronym was also rendered "Pacer" and glossed as transparency and risk [unverified]. The intent is a score or a living model, not only a static list.

Minimum disclosure: zero-knowledge proofs. The example was buying alcohol. The machine needs "over the legal age in this place," not a birth date. The age itself was noted as jurisdiction-specific: 21 in the United States, 18 in Switzerland and France, possibly lower elsewhere. That dependence on local rules was tied back to heterogeneous control. The Trust over IP ZKP task force was identified as the place this minimum-disclosure work is being driven. A Google zero-knowledge protocol was mentioned as something whose difference from that work is still being sorted out [unverified which protocol].

Terms: IEEE 7012-2025, called My Terms, dated to roughly October or November of the previous year. The website presents terms and the person clicks through. The standard is a framework for the person to bring machine-readable privacy terms, for the two sides to agree the overlap, and for that overlap to be contractually bound. What those contracts are in practice is unfinished. A separate IEEE industry-connections program is looking at deployment. The person's lever, as stated, is to say that information shared with a given service may not be sold on.

Control, offered as a discussion point rather than a finished design: those agreed terms become a verifiable credential that travels with the data. The credential can be checked at boundaries — a system boundary, a company or platform boundary, or a regulatory boundary such as a rule that data not leave a jurisdiction. The obligations in the terms are then testable where the data goes, which was also offered as one reading of the self-healing principle. The point was to stop scraping and reuse that the person did not agree to. No company was named as an example.

A room addition on My Terms: one of the first agreements already reached in that work is no third-party cookies or tracking, only a first-party cookie agreement. If both the person and the site carry that term,

only first-party cookies are set. The documented services-only agreement is SD-BASE. The caption's suffix and exact cookie configuration remain unconfirmed; a services-only agreement should not be reduced to a cookie-setting mechanism.

The session then broke for lunch, explicitly to keep discussing these three contributions. A scheduling aside: an industry session had already been absorbed into the day, so this room was not late for a separate industry block.

**After the scheduled close, still on this recording.** The tail is fragmented. A few claims are substantive enough to keep, and they were not turned into decisions.

A human credential for something like hiring was distinguished from device signals that a login is not coming from a device farm. Location was one such signal. A rental example was only half audible: the rental company receives a hash, not the full underlying data [unverified].

Skepticism that the proof-of-human infrastructure is commercially neutral. The reply: operators have to be paid; the stated ambition is not to exploit the biometric data; the infrastructure is the product. How the project makes money was left as the regulator's next question.

The earlier token distribution was described, with hindsight, as a way to get a critical mass of humans verified. The claim now: verification is no longer paid by giving the user a token. The hoped-for steady state is a fee that pays network operators. The token was said to create a policy problem because it is heard as speculative crypto rather than as a fee inside a working network.

Fee design, as stated: the relying party pays for a proof-of-human check, not the user. With a market-structure bill described as not passed, guidance attributed to the SEC was that those fees need to be charged programmatically. An "ICO" characterization of the token was rejected in the room. The payment-rail sentences are partly garbled and should not be treated as a settled legal description.

Japan was named as a market where both the identity function and a financial-network function matter: access to services that today depend on a passport or on KYC. A Japanese regulatory discussion was only partly intelligible: a next step "under the security approach," and a distinction between qualified and unqualified layer-1 treatment [unverified].

A research follow-up was invited. Independent peer review, not a paid sponsorship, was said to be more valuable. Elements of how the network works were proposed as a paper. Pain points were said to be clear enough now to propose topics. No topic list was agreed. A side exchange about who at a university actually operates a node, and whether a data-protection contact exists, did not resolve.

### Matters not resolved

Unlinkability as the name of the outcome, versus linkability as a graded metric. The taxonomy authors defended the metric because some flows want linkage. The wording change was not rejected and was not made.

Whether a sanctions non-match or an age proof can stand in for KYC. The room's regulatory comment said no. That was an objection to a common industry claim, not a dispute about the taxonomy's question list.

Global uniqueness versus a community-sized aperture. Both were presented as real designs. They were not reconciled. Global uniqueness and cross-context unlinkability were explicitly said to pull against each other.

Whether capture mitigations sit inside the proof's trust boundary or outside it.

Whether a zero-knowledge commitment preserves ISO/IEC 24745 renewability or freezes the template.

What proves a human was present when an agent token was issued. Block 14 left this open. This session added enrollment, delegation, and action as different moments, and did not pick a required check at each.

Intent drift, permission expansion, and an agent arriving in a new environment: cited as cases where agentic-custody work has no agreed response.

Device integrity assumed, versus device integrity measured and composed. The room rejected bare trust in the phone. It did not pick a measurement product.

Whether a higher-integrity capture should change the uniqueness statement or only a risk score. The answer given was the risk score. It was offered as a mental model.

Self-built orbs. Cryptographic similarity is not canonical enrollment. How TEE attestation replaces the closed security chip is unfinished. Network effects were the proposed answer to a flood of non-canonical identities, not a completed design.

Enrollment of the wrong live person. Biometrics do not catch it. No process standard was adopted.

Eye injury and failed re-enrollment. No solution was claimed.

Agent authority as a taxonomy category. Marked as needing its own treatment.

Whether agreed privacy terms should travel as a verifiable credential and be checked at jurisdictional and platform boundaries. Raised, not adopted.

Which Google zero-knowledge protocol is being compared with the Trust over IP work. Unresolved in the room.

Token, fee switch, and who pays. Described, and recognized as a regulatory question. Not a BGIN position.

What academic work on this network would actually study. Left for a later proposal. Sponsored versus independent review was a preference, not a scope.

### Disposition of the work

Proof of personhood, World ID, and the ZKP taxonomy are a multi-block BGIN subject, at least six blocks deep, with an archive the room expects agent tooling to survey. This session did not adopt a BGIN draft. It collected three external contributions and a set of edits.

The taxonomy exists as a working document on the proof-of-human side. It already separates humanity, uniqueness, presence, and attributes. It does not yet integrate capture assurance, aperture, or freshness. The authors agreed those go deeper and that they will follow up. ISO mapping was requested and not done in the room.

ProveKit version 1 was described as public, at provekit.org, open source, and about a month old. Version 2 was hoped for inside a year. Face-image proving on a phone is the known gap. No production zero-knowledge layer was claimed for the ordinary-camera face-verification system. That work sits in the Trust over IP ZKP task force and may feed a W3C confidence-method task force.

The edge-trust product is in stealth. The public artifacts named were an IEEE white paper on the five principles, the TRACER question list on IEEE Xplore, IEEE 7012-2025, and a follow-on IEEE industry program on deploying My Terms. The "terms travel as a verifiable credential" idea is pre-design.

The MPC deployment was described as five nodes, with the University of Tokyo the latest, and with cost of node operation still a barrier to widening the set. Canonical issuance still depends on a closed security chip, with TEEs proposed as the replacement. A palm-scanner credential was described as grant-seeded and not as a finished BGIN work item.

## Actions

Each action is written so that it can be tracked without the rest of the record. Where the room named only a person, the action is kept and the name is omitted.

Fold capture assurance, uniqueness aperture, and freshness into the taxonomy, and decide whether linkability stays a metric or whether unlinkability becomes the named outcome.

Align category names with existing biometric and identity standards. The unlinkable-authentication pointer was to be dropped in the chat. ISO/IEC 27551, ISO/IEC 24745, and ISO/IEC 30107 are the named hooks.

Share the contributed documents. Further discussion of aperture was requested. Freshness math was offered back to that discussion.

Keep agent authority as its own work, distinct from "a human existed at issuance." The open Block 14 point — what proves a human was present when a token was issued — is now explicitly about delegation and about later actions.

Treat device-integrity measurement as a composable input to capture assurance, not as a synonym for liveness.

ProveKit: local circuits are the current artifact; on-device face comparison is the stated research limit; version 2 is the near release.

Lunch was the continuation of this session, not a decision meeting. No consensus text was read out.

A later research conversation with academic partners was left open, preferably with independent review. No question list was fixed. Japan market and fee-design questions were flagged as policy follow-ups, not as drafting tasks.

## Coverage

This record covers the published privacy session in Room B, from the session opening through the lunch gap. Figures are reported session claims, not independently validated measurements. Technical names are corrected where supported by the recording, chat, or identified primary documentation.

Where a name could not be checked against another part of the same recording, it is left unverified rather than guessed. Logistics, introductions, and names of speakers are omitted.

Dropped as noise: greetings and travel small talk, camera and "orb in the ceiling" jokes, screen-share setup, a high-school debate aside, lunch sponsorship logistics, people leaving for other panels, an electrician, and the long tail of introductions, cities, and social plans after the close. Personal names from introductions and from the hallway conversation are omitted on purpose.

The post-close policy and research fragments are summarized above and should not be upgraded into session decisions. Several sentences in that tail are unintelligible and were not reconstructed.

—.

**Source clarifications and open checks**

"Tasio" as a cryptographic collaborator. Nethermind was distinct and is not listed here.

Palm-scanner project rendered "base scanner," "OnBase scan," and "palmade scanner.".

TRACER also rendered "Pacer.".

Editorial check: SD-BASE is the documented services-only agreement label. The caption suffix and precise cookie configuration are not established by the retrieved source.

Which Google protocol was meant.

"Qualified" versus "unqualified" layer 1 in the Japan regulatory fragment.

The public human-only advertising announcement identifies Hakuhodo. This resolves the organization name without identifying any meeting participant.

AMPC means anonymized multi-party computation in the World ID material; it is a specific MPC deployment term, not a misspelling to normalize away.